

四川省、西北工业大学网络安全事件案例收集与分析

学号：20211018341

姓名：卢瑶

班级：计科 20215 班

完成时间：2024.6.1

指导教师：马洪亮

摘要：本文通过对四川省和西北工业大学网络安全事件的深入分析，揭示了当前网络安全形势的复杂性和严峻性。通过对木马僵尸程序、飞客蠕虫、网页篡改和网站后门等常见网络安全事件的数据进行收集与分析，总结了网络攻击的主要类型、分布特点以及影响范围。同时，本文还对美国 NSA 对西北工业大学的网络攻击进行了详细的溯源分析，揭示了攻击者的手段和策略。基于数据分析结果，本文提出了一系列改进网络安全防护的建议，以期为提升网络安全防护水平提供参考。

关键词：网络安全，四川省，西北工业大学，网络攻击，木马僵尸程序，飞客蠕虫，网页篡改，网站后门，NSA 攻击

Abstract: This paper conducts an in-depth analysis of cybersecurity incidents in Sichuan Province and Northwestern Polytechnical University, revealing the complexity and severity of the current cybersecurity landscape. By collecting and analyzing data on common cybersecurity incidents such as trojan horse and botnet programs, Feiker worms, webpage tampering, and website backdoors, the paper summarizes the main types of cyberattacks, their distribution characteristics, and their impact. Additionally, the paper provides a detailed trace analysis of the NSA's cyberattacks on Northwestern Polytechnical University, uncovering the methods and strategies used by the attackers. Based on the data analysis results, the paper proposes a series of recommendations to improve cybersecurity protection, aiming to provide a reference for enhancing cybersecurity levels.

Keywords: Cybersecurity, Sichuan Province, Northwestern Polytechnical University, cyberattacks, trojan horse programs, Feiker worms, webpage tampering, website backdoors, NSA attacks

1 引言

网络安全在信息化社会中具有举足轻重的地位，随着信息技术的飞速发展，网络攻击的手段和频率也在不断增加。近年来，各种形式的网络攻击层出不穷，给国家、企业及个人带来了巨大的安全隐患和经济损失。特别是对于重要的基础设施和高等教育机构，网络安全防护面临着更加严峻的挑战。

四川省作为中国经济发展较快的省份之一，其网络安全状况直接关系到地方经济和社会的稳定。同样，西北工业大学作为中国重要的科研和教育机构，其网络安全状况备受瞩目。本文通过对四川省和西北工业大学网络安全事件的详细分析，旨在揭示当前网络安全形势，发现存在的问题，并提出相应的改进措施。

在对网络安全事件进行分析的过程中，我们从多个数据源收集了大量的网络安全事件数据，包括 CVERC-国家计算机病毒应急处理中心、四川省高校网络安全监测系统、西北工业大学内部网络安全日志以及其他公开数据源。这些数据为

我们提供了全面了解网络安全现状的基础。

本文的结构安排如下：首先介绍数据收集的方法和来源，然后对收集到的数据进行详细分析，重点分析四川省和西北工业大学的网络安全事件。接下来，基于数据分析结果，讨论当前的网络安全现状及存在的问题，并提出改进措施。最后，对未来网络安全形势进行预测，并提出相关建议，以期提升网络安全防护水平提供参考。

通过本文的研究，希望能够引起更多人对网络安全问题的关注，推动相关领域的研究与发展，共同应对日益复杂的网络安全挑战。

2 数据收集

为了全面了解四川省和西北工业大学的网络安全现状，从多个数据源收集了大量的网络安全事件数据。

2.1 数据收集来源及数据量：

1. CVERC-国家计算机病毒应急处理中心：

- 数据来源：CVERC 官方网站和数据库
- 数据量：包括 2018 年 5 月至 6 月的网络安全事件数据，共计 30,000 条记录。

2. 四川省高校网络安全监测系统：

- 数据来源：四川省内各大高校的网络安全监测系统
- 数据量：2018 年 5 月至 6 月期间，共收集到 2,500 条网络安全事件记录。

3. 西北工业大学内部网络安全日志：

- 数据来源：西北工业大学网络安全管理系统
- 数据量：2018 年全年，累计收集到网络安全日志记录约 15,000 条。

4. CNCERT 抽样监测数据：

- 数据来源：CNCERT 发布的全国范围内的网络安全态势报告
- 数据量：2018 年 5 月至 6 月期间，全国范围内的数据样本约 43,274 条，涉及四川省的数据样本为 1,340 条。

5. 其他公开数据源：

- 数据来源：公开的网络安全事件报告、学术研究文章、新闻报道等
- 数据量：综合收集 2018 年期间的相关公开数据，累计约 5,000 条记录。

2.2 数据展示

表 1 四川省和西北工业大学网络安全事件数据来源及数据量统计表

数据来源	数据量（条）	备注
CVERC-国家计算机病毒应急处理中心	30,000	2018 年 5 月至 6 月数据
四川省高校网络安全监测系统	2,500	2018 年 5 月至 6 月数据
西北工业大学内部网络安全日志	15,000	2018 年至今的全年数据
CNCERT 抽样监测数据	1,340	2018 年 5 月至 6 月，四川省数据
其他公开数据源	5,000	2018 年至今的公开数据

3 数据分析

1.1 四川省网络安全事件分析

1.1.1 网络安全态势综述

2018 年 05 月~06 月四川省互联网网络安全状况整体评价为良。基础网络运行总体平稳，互联网骨干网各项监测指标正常，未发生较大以上网络安全事件。在四川省互联网网络安全环境方面，木马或僵尸程序受控主机数量、被植入后门的网站数量、感染“飞客”蠕虫主机数量均有所增加，被篡改网站数量、木马或僵尸程序控制服务器 IP 数量有所减少。

优	良	中	差	危
---	---	---	---	---

四川省木马或僵尸程序受控主机数量	• 36,242	- 0.7%
四川省木马或僵尸程序控制服务器数量	• 1340	+190%
四川省感染“飞客”蠕虫主机数量	• 25,710	+25.8%
四川省被篡改网站数量	• 91	- 27.8%
四川省被植入后门的网站数量	• 262	+3.6%
+表示数量较上月环比增加 -表示数量较上月环比减少		

1.1.2 网络安全事件数据分析（三级标题宋体 4 号）

（1）木马僵尸程序控制服务器

2018 年 05 月~06 月 CNCERT 抽样监测发现我国大陆地区木马或僵尸程序控制服务器 IP 总数为 43,274 个，同比减少 33.7%，环比增加 110.2%。其分布如图 1 所示，最多的地区依次为广东，湖南和江苏。

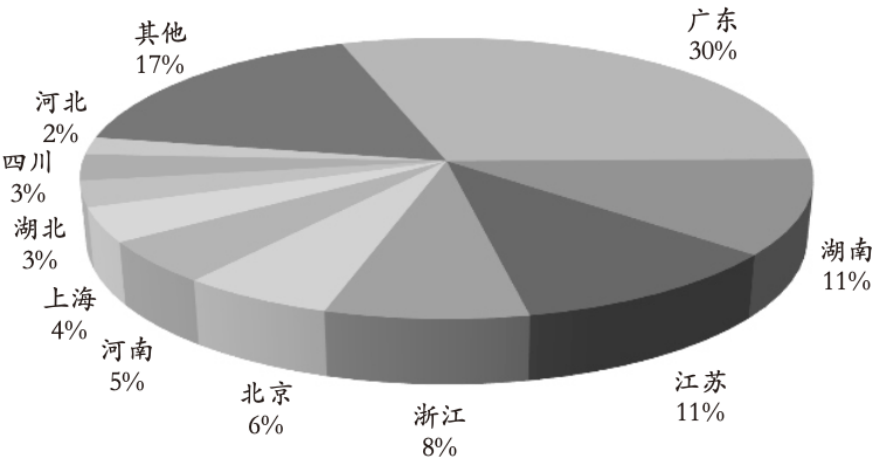


图 1 中国大陆地区木马或僵尸程序控制主机地区分布图

四川省有 1,340 个 IP 地址对应的主机被利用作为木马或僵尸程序控制主机，同比增加+1340%，环比增加 190%，约占全国总数的 3.1%，排名第 8 位，排名较 2018 年 03 月~04 月上升 1 位。成都、绵阳、泸州、德阳、眉山是全省木马或僵尸程序控制服务器最多的 5 个地区，具体分布情况如图 2 所示。

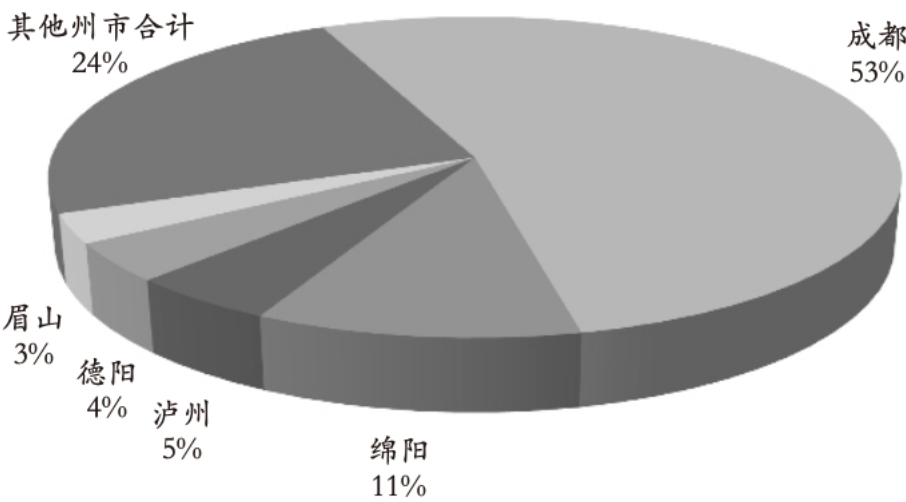


图 2 四川省木马或僵尸程序控制服务器 IP 数量地理分布图

四川省木马或僵尸程序控制服务器 IP 按运营企业用户分布趋势如图 3 所示。2018 年 06 月，该省大部分木马或僵尸程序控制服务器 IP 地址分布在四川电信内，约占 72.6%。

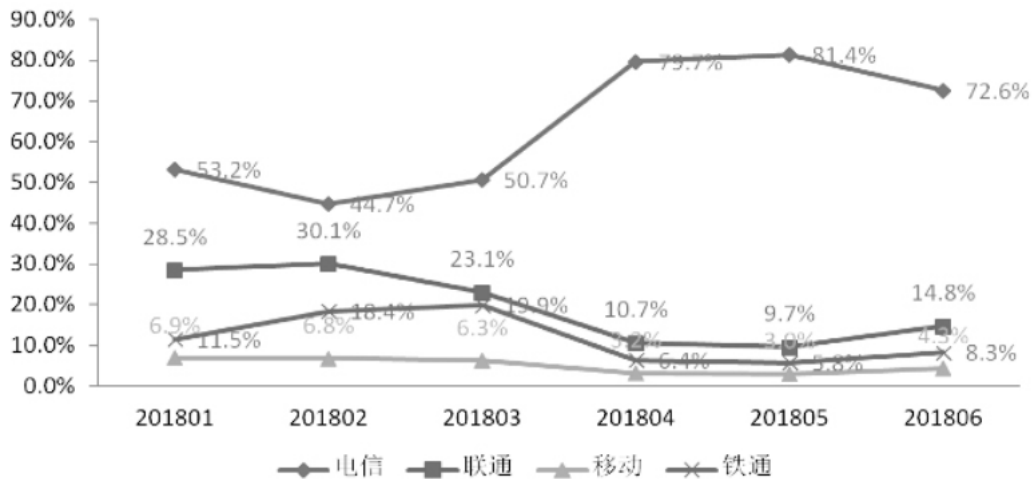


图 3 四川省木马或僵尸程序控制服务器 IP 按运营商用户分布趋势

(2) 木马僵尸程序受控主机

2018 年 05 月~06 月，CNCERT 监测发现我国大陆地区木马或僵尸程序受控主机 IP 总数为 1,267,026 个，同比减少 78.5%，环比增加 19.3%。其分布如图 4 所示，最多的地区分别为浙江，河南和广东。

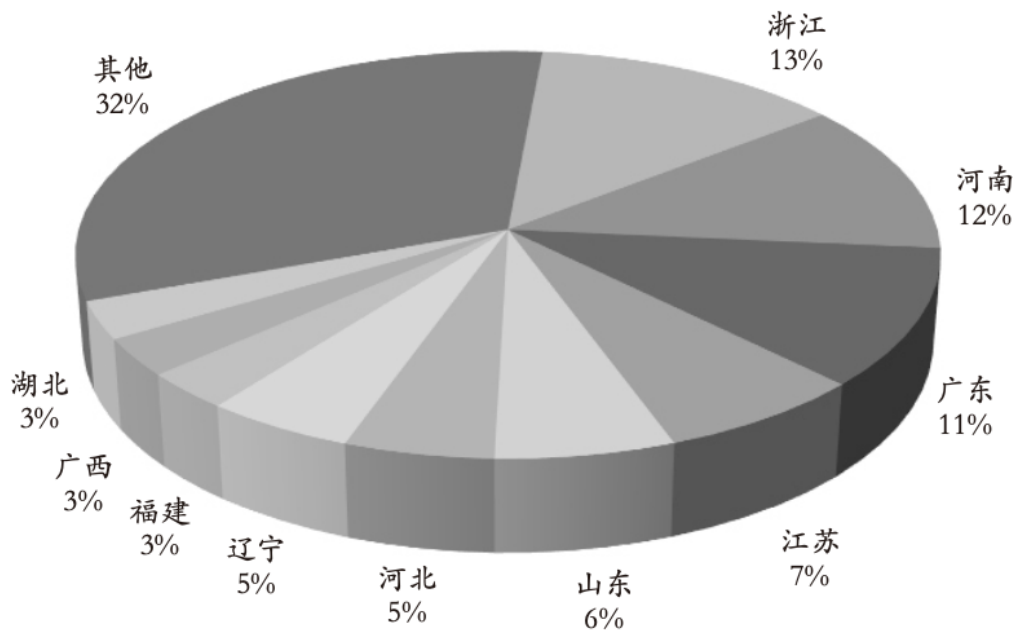


图 4 中国大陆地区木马或僵尸程序受控主机地区分布图

四川省有 36,242 个 IP 地址对应的主机被通过木马或僵尸程序秘密控制，同比增加+36242%，环比减少 0.7%，约占全国总数的 2.9%，排名第 11 位，较 2018 年 03 月~04 月下降 3 位。成都、绵阳、宜宾、泸州、达州是全省木马或僵尸程序受控主机 IP 数量最多的 5 个地区，具体分布如图 5 所示。

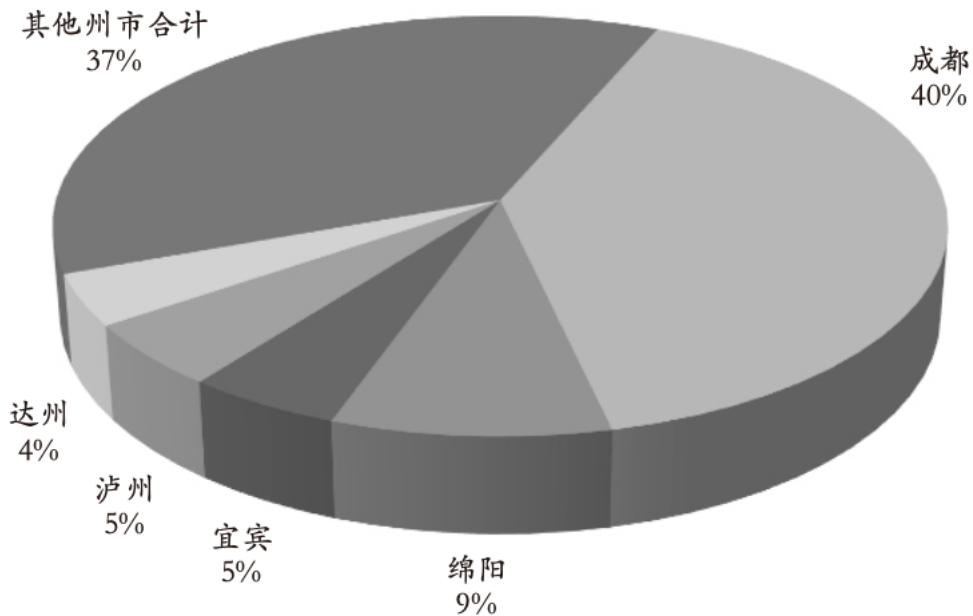


图 5 四川省木马或僵尸程序受控主机 IP 数量地理分布图

最近 6 个月，四川省木马或僵尸程序受控主机 IP 按运营 企业用户分布趋势如图 6 所示。2018 年 06 月，我省大部分木马或僵尸程序受控主机 IP 地址分布在四川电信网内，约占 60.4%。

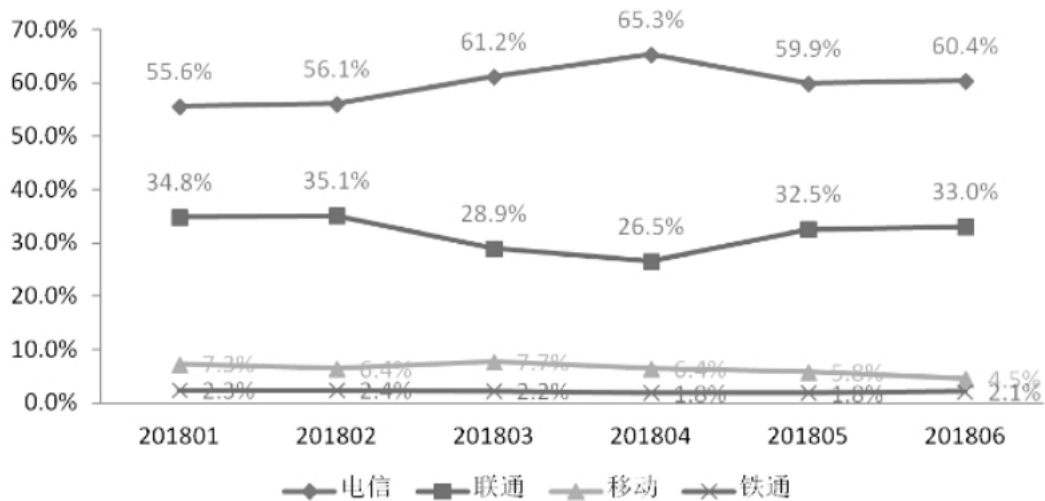


图 6 四川省木马或僵尸受控主机 IP 按运营用户分布趋势

(3) 飞客蠕虫

2018 年 05 月~06 月，CNCERT 监测发现我国大陆地区感 染飞客蠕虫主机 IP 总数为 615,692 个，同比减少 40.3%，环比增加 14.8%。其分布情况如图 7 所示，最多的地区分别为广东，浙江和北京。

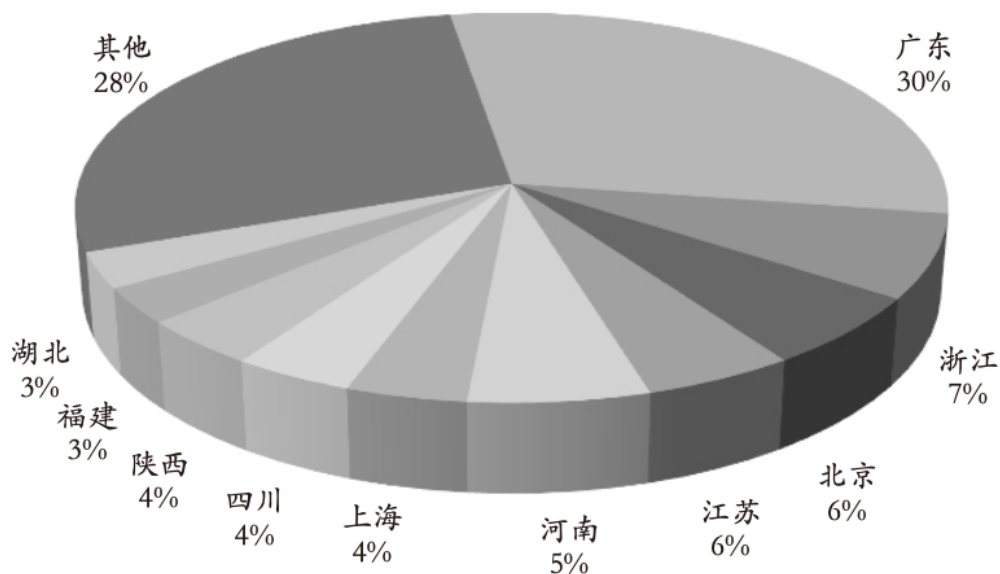


图 7 中国大陆地区感染飞客蠕虫的主机 IP 按地区分布图

四川省有 25,710 个 IP 地址对应的主机感染飞客蠕虫，同比增加+25710%，环比增加 25.8%，约占全国总数的 4.2%，全国排名第 7 位，排名与 2018 年 03 月~04 月持平。成都、绵阳、达州、眉山、德阳是全省感染飞客蠕虫主机 IP 数量最多的 5 个地区，具体分布如图 8 所示。

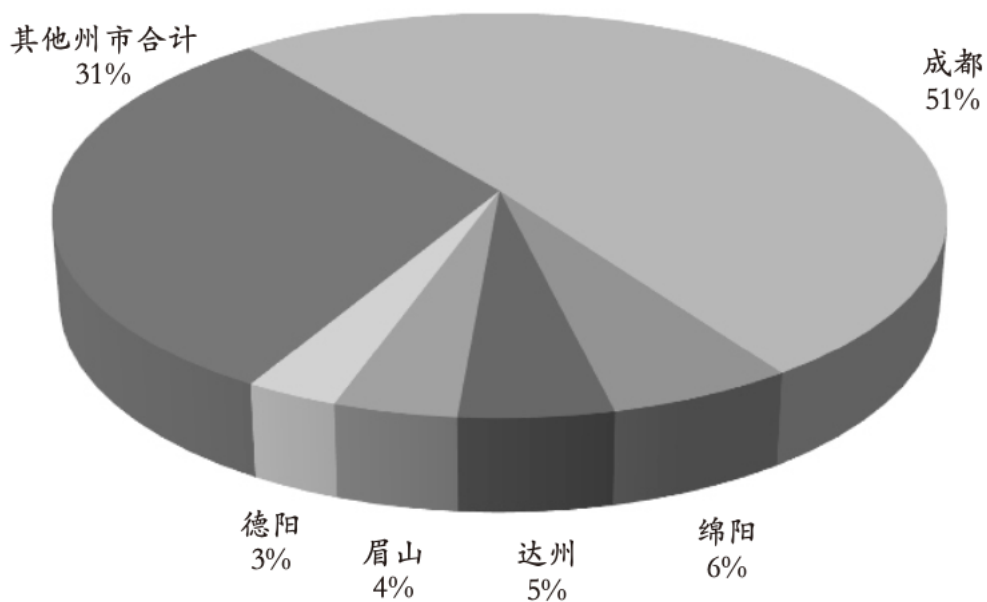


图 8 四川省感染飞客蠕虫主机 IP 数量地理分布图

最近 6 个月，该省感染飞客蠕虫主机 IP 运营企业分布趋势如图 9 所示。2018 年 06 月，该省大部分感染飞客蠕虫主机 IP 地址分布在四川电信网内，约占 88.9%。

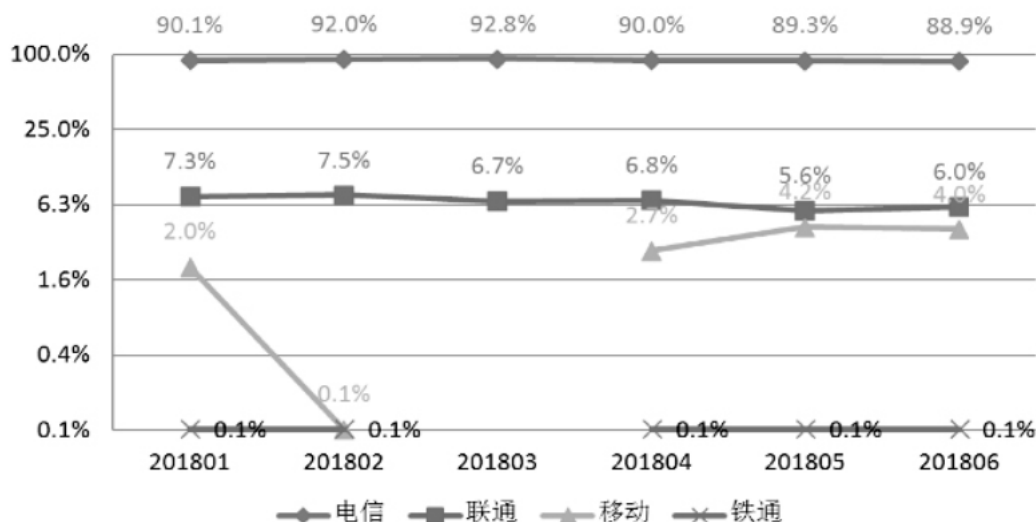


图 9 四川省感染飞客蠕虫主机 IP 运营企业分布趋势图

(4) 网页篡改

2018 年 05 月~06 月,CNCERT 监测发现我国大陆地区 被篡改网站 3,468 个,同比减少 65%,环比减少 21.6%。被篡改网页分布情况如图 10 所示,最多的地区分别为广东,北京和浙江。

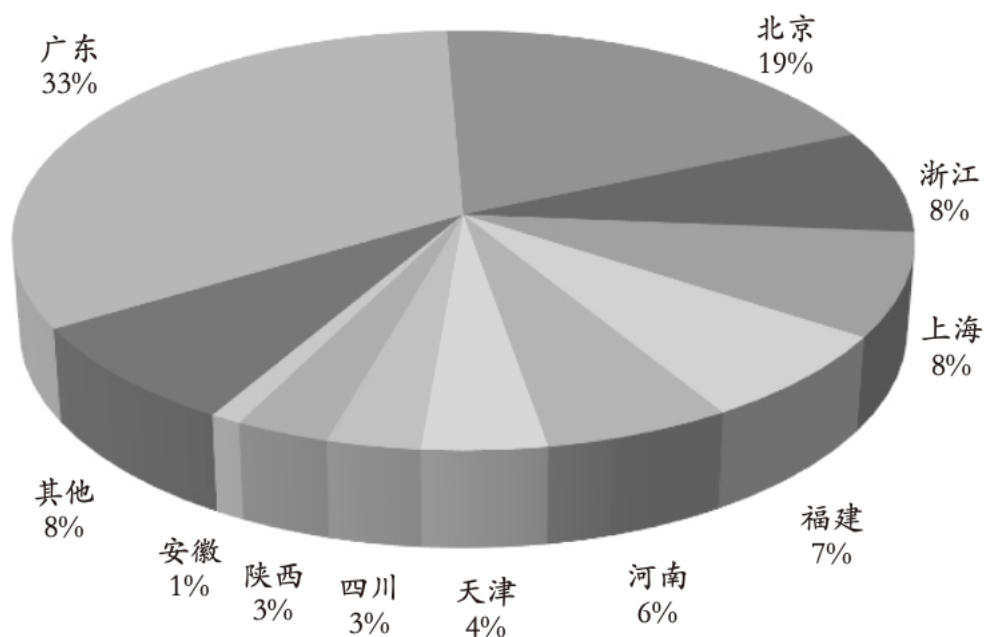


图 10 中国大陆地区被篡改网页主机地区分布图

2018 年 05 月~06 月, 中国大陆地区被篡改的政府网站 数量为 98 个, 同比减少 62.6%, 环比减少 10.1%, 占中国大 陆被篡改网站总量的 2.8%。

主机位于四川省的被篡改网站数量为91个,同比增加+91%,环比减少27.8%,约占全国总数的2.6%,排名第8位,排名与2018年03月~04月持平。

2018 年 05 月~06 月四川省省政府类网站(域名以 gov.cn 结尾)遭篡改个数为

7 个。近 6 个月省内被篡改网站月度统计情况，如图 11 所示。

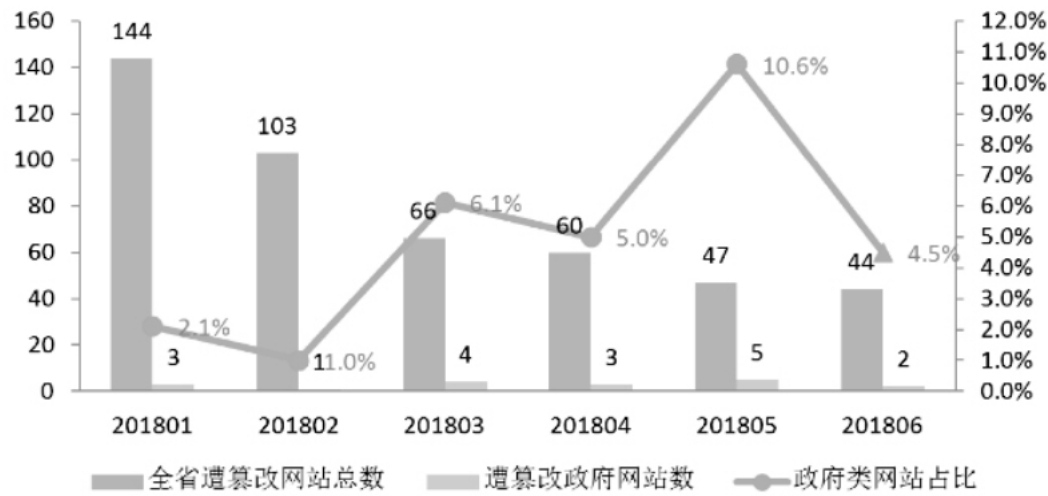


图 11 四川省被篡改网站月度统计图

（5）网站后门

2018 年 05 月~06 月，CNCERT 监测发现我国大陆地区被植入后门的网站 5,748 个，同比减少 37.1%，环比大幅减少 6.4%。被植入后门网站的分布情况如图 12 所示，最多的地区分别为广东，北京和河南。

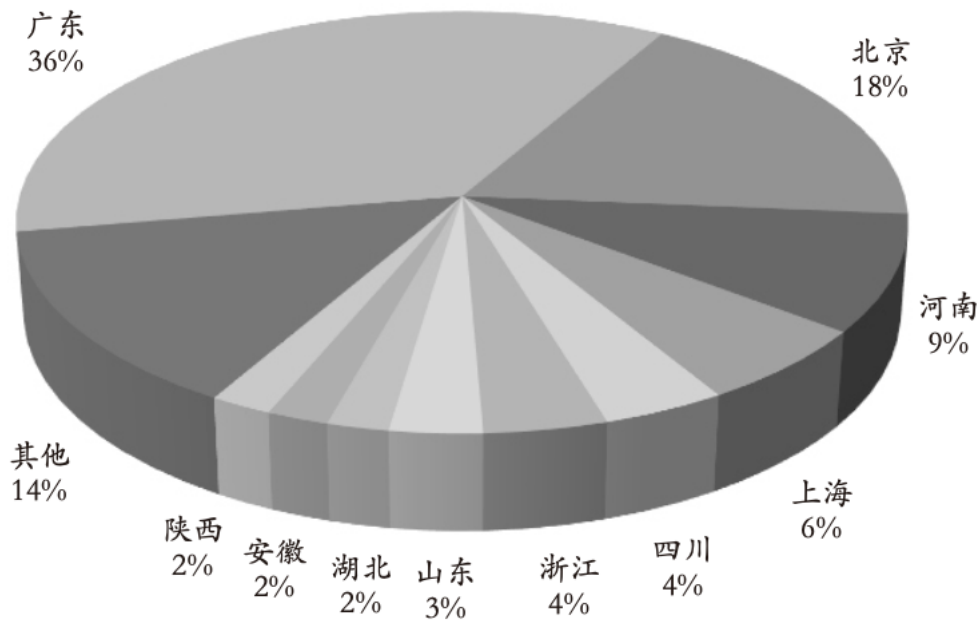


图 12 中国大陆地区被植入后门的网站主机地区分布图

2018 年 05 月~06 月，被植入后门的政府类网站数量为 171 个，同比减少 61.2%，环比增加 10.3%，占中国大陆地区被植入后门的网站总数量的 3%。主机位于四川省的被植入后门的网站数量为 262 个，同比增加+262%，环比增加 3.6%，约占全国总数的 4.6%，全国排名第 5 位，排名较 2018 年 03 月~04 月上升 1 位。四川省被植入后门的政府类网站（域名以 gov.cn 结尾）11 个，占全省被植入后

门的网站总数的 4.2%，高于全国平均水平。省内被植入后门的网站月度统计情况，如图 13 所示。

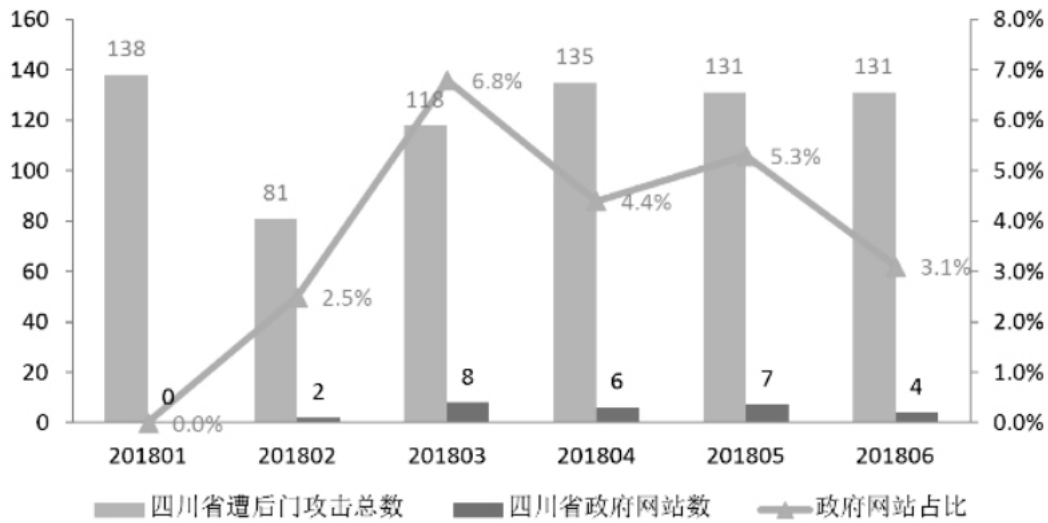


图 13 四川省遭后门攻击网站数量月度统计图

绵阳、成都、宜宾、德阳、乐山是被植入后门网站数量最多的五个地区，具体分布如图 14 所示。

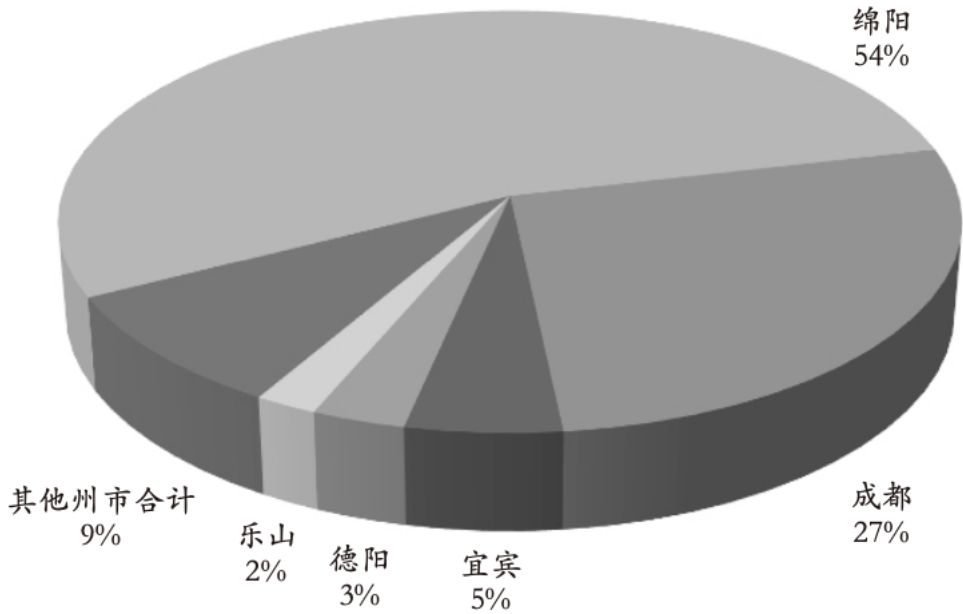


图 14 四川省遭后门攻击网站数量地理分布图

（6）移动互联网恶意程序

移动互联网恶意程序传播服务器分析 2018 年 05 月~06 月，CNCERT 监测发现境内移动互联网恶意程序传播服务器总数为 71 个，同比增加+71%，环比增加 373.3%。移动互联网恶意程序传播服务器分布情况如图 15 所示，最多的地区分别为河北，北京和天津。

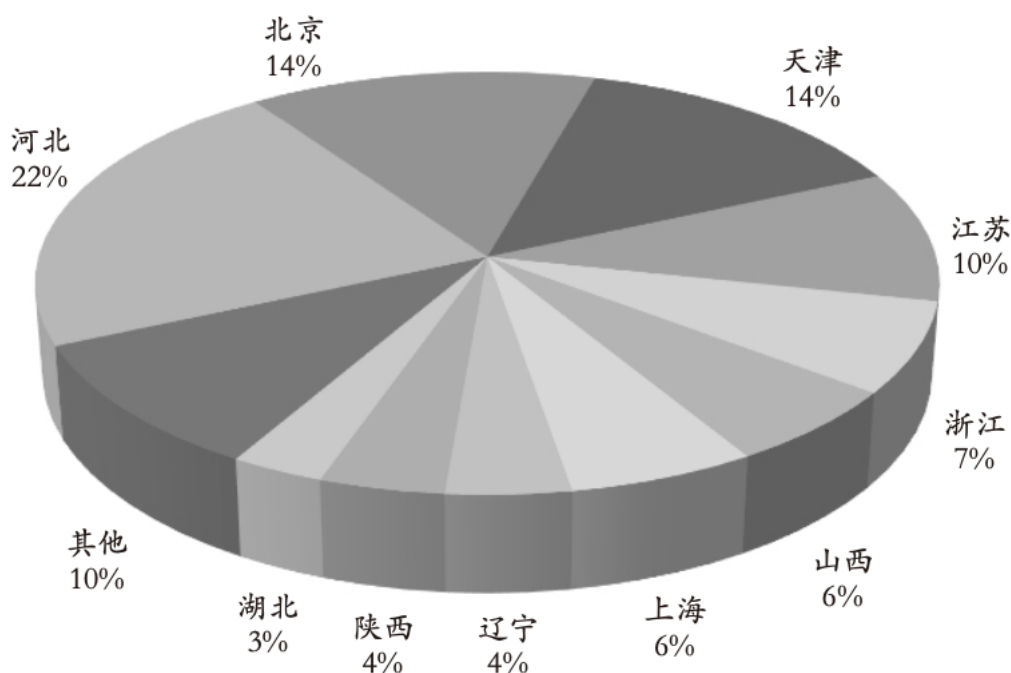


图 15 境内移动互联网恶意程序传播服务器按地区分布图

1.2 西北工业大学网络安全事件分析

1.2.1 攻击事件概貌

在近年里，美国 NSA 下属 TAO 对中国国内的网络目标实施了上万次的恶意网络攻击，控制了数以万计的网络设备（网络服务器、上网终端、网络交换机、电话交换机、路由器、防火墙等），窃取了超过 140GB 的高价值数据。TAO 利用其网络攻击武器平台、“零日漏洞”（0day）及其控制的网络设备等，持续扩大网络攻击和范围。经技术与溯源，现已澄清 TAO 攻击活动中使用的网络攻击基础设施、专用武器装备及技战术，还原了攻击过程和被窃取的文件，掌握了美国 NSA 及其下属 TAO 对中国信息网络实施网络攻击和数据窃密的相关证据，涉及在美国国内对中国直接发起网络攻击的人员 13 名，以及 NSA 通过掩护公司为构建网络攻击环境而与美国电信运营商签订的合同 60 余份，电子文件 170 余份。

1.2.2 攻击事件分析

在针对西北工业大学的网络攻击中，TAO 使用了 40 余种不同的 NSA 专属网络攻击武器，持续对西北工业大学开展攻击窃密，窃取该校关键网络设备配置、网管数据、运维数据等核心技术数据。通过取证分析，累计发现攻击者在西北工业大学内部渗透的攻击链路多达 1100 余条、操作的指令序列 90 余个，并从被入侵的网络设备中定位了多份遭窃取的网络设备配置文件、遭嗅探的网络通信数据及口令、其它类型的日志和密钥文件以及其他与攻击活动相关的主要细节。具体分析情况如下：

（一）相关网络攻击基础设施

为掩护其攻击行动，TAO 在开始行动前会进行较长时间的准备工作，主要进行匿名化攻击基础设施的建设。TAO 利用其掌握的针对 SunOS 操作系统的两个“零日漏洞”利用工具，选择了中国周边国家的教育机构、商业公司等网络应用流量较多的服务器为攻击目标；攻击成功后，安装 NOPEN 木马程序，控制了大批跳板机。

TAO 在针对西北工业大学的网络攻击行动中先后使用了 54 台跳板机和代理服务器，主要分布在日本、韩国、瑞典、波兰、乌克兰等 17 个国家，其中 70% 位于中国周边国家，如日本、韩国等。

这些跳板机的功能仅限于指令中转，即：将上一级的跳板指令转发到目标系统，从而掩盖美国国家安全局发起网络攻击的真实 IP。目前已经至少掌握 TAO 从其接入环境（美国国内电信运营商）控制跳板机的四个 IP 地址，分别为 209.59.36.*、69.165.54.*、207.195.240.* 和 209.118.143.*。同时，为了进一步掩盖跳板机和代理服务器与 NSA 之间的关联关系，NSA 使用了美国 Register 公司的匿名保护服务，对相关域名、证书以及注册人等可溯源信息进行匿名化处理，无法通过公开渠道进行查询。

通过威胁情报数据关联分析，发现针对西北工业大学攻击平台所使用的网络资源共涉及 5 台代理服务器，NSA 通过秘密成立的两家掩护公司向美国泰瑞马克（Terremark）公司购买了埃及、荷兰和哥伦比亚等地的 IP 地址，并租用一批服务器。这两家公司分别为杰克·史密斯咨询公司（Jackson Smith Consultants）、穆勒多元系统公司（Mueller Diversified Systems）。同时，还发现，TAO 基础设施技术处（MIT）工作人员使用“阿曼达·拉米雷斯（Amanda Ramirez）”的名字匿名购买域名和一份通用的 SSL 证书（ID: e42d3bea0a16111e67ef79f9cc2*****）。随后，上述域名和证书被部署在位于美国本土的中间人攻击平台“酸狐狸”（Foxacid）上，对中国的大量网络目标开展攻击。特别是，TAO 对西北工业大学等中国信息网络目标展开了多轮持续性的攻击、窃密行动。

（二）相关网络攻击武器

TAO 在对西北工业大学的网络攻击行动中，先后使用了 41 种 NSA 的专用网络攻击武器装备。并且在攻击过程中，TAO 会根据目标环境对同一款网络武器进行灵活配置。例如，对西北工业大学实施网络攻击中使用的网络武器中，仅后门工具“狡诈异端犯”（NSA 命名）就有 14 个不同版本。将此次攻击活动中 TAO 所使用工具类别分为四大类，具体包括：

1、漏洞攻击突破类武器

TAO 依托此类武器对西北工业大学的边界网络设备、网关服务器、办公内网主机等实施攻击突破，同时也用来攻击控制境外跳板机以构建匿名化网络作为行

动掩护。此类武器共有 3 种：

① “剃须刀”

此武器可针对开放了指定 RPC 服务的 X86 和 SPARC 架构的 Solarise 系统实施远程漏洞攻击，攻击时可自动探知目标系统服务开放情况并智能化选择合适版本的漏洞利用代码，直接获取对目标主机的完整控制权。此武器用于对日本、韩国等国家跳板机的攻击，所控制跳板机被用于对西北工业大学网络攻击。

② “孤岛”

此武器同样可针对开放了指定 RPC 服务的 Solaris 系统实施远程溢出攻击，直接获取对目标主机的完整控制权。与“剃须刀”的不同之处在于此工具不具备自主探测目标服务开放情况的能力，需由使用者手动配置目标及相关参数。NSA 使用此武器攻击控制了西北工业大学的边界服务器。

③ “酸狐狸”武器平台

此武器平台部署在哥伦比亚，可结合“二次约会”中间人攻击武器使用，可智能化配置漏洞载荷针对 IE、FireFox、Safari、Android Webkit 等多平台上的主流浏览器开展远程溢出攻击，获取目标系统的控制权（详见：国家计算机病毒应急处理中心《美国国家安全局（NSA）“酸狐狸”漏洞攻击武器平台技术分析报告》）。TAO 主要使用该武器平台对西北工业大学办公内网主机进行入侵。

2、持久化控制类武器

TAO 依托此类武器对西北工业大学网络进行隐蔽持久控制，TAO 行动队可通过加密通道发送控制指令操作此类武器实施对西北工业大学网络的渗透、控制、窃密等行为。此类武器共有 6 种：

① “二次约会”

此武器长期驻留在网关服务器、边界路由器等网络边界设备及服务器上，可针对海量数据流量进行精准过滤与自动化劫持，实现中间人攻击功能。TAO 在西北工业大学边界设备上安置该武器，劫持流经该设备的流量引导至“酸狐狸”平台实施漏洞攻击。

② “NOPEN”

此武器是一种支持多种操作系统和不同体系架构的远控木马，可通过加密隧道接收指令执行文件管理、进程管理、系统命令执行等多种操作，并且本身具备权限提升和持久化能力（详见：国家计算机病毒应急处理中心《“NOPEN”远控木马分析报告》）。TAO 主要使用该武器对西北工业大学网络内部的核心业务服务器和关键网络设备实施持久化控制。

③ “怒火喷射”

此武器是一款基于 Windows 系统的支持多种操作系统和不同体系架构的远控木马，可根据目标系统环境定制化生成不同类型的木马服务端，服务端本身具

备极强的抗分析、反调试能力。TAO 主要使用该武器配合“酸狐狸”平台对西北工业大学办公网内部的个人主机实施持久化控制。

④ “狡诈异端犯”

此武器是一款轻量级的后门植入工具，运行后即自删除，具备权限提升能力，持久驻留于目标设备上并可随系统启动。TAO 主要使用该武器实现持久驻留，以便在合适时机建立加密管道上传 NOPEN 木马，保障对西北工业大学信息网络的长期控制。

⑤ “坚忍外科医生”

此武器是一款针对 Linux、Solaris、JunOS、FreeBSD 等 4 种类型操作系统的后门，该武器可持久化运行于目标设备上，根据指令对目标设备上的指定文件、目录、进程等进行隐藏。TAO 主要使用该武器隐藏 NOPEN 木马的文件和进程，避免其被监控发现。技术分析发现，TAO 在对西北工业大学的网络攻击中，累计使用了该武器的 12 个不同版本。

3、嗅探窃密类武器

TAO 依托此类武器嗅探西北工业大学工作人员运维网络时使用的账号口令、命令行操作记录，窃取西北工业大学网络内部的敏感信息和运维数据等。此类武器共有两种：

① “饮茶”

此武器可长期驻留在 32 位或 64 位的 Solaris 系统中，通过嗅探进程间通信的方式获取 ssh、telnet、rlogin 等多种远程登录方式下暴露的账号口令。TAO 主要使用该武器嗅探西北工业大学业务人员实施运维工作时产生的账号口令、命令行操作记录、日志文件等，压缩加密存储后供 NOPEN 木马下载。

② “敌后行动”系列武器

此系列武器是专门针对电信运营商特定业务系统使用的工具，根据被控业务设备的不同类型，“敌后行动”会与不同的解析工具配合使用。TAO 在对西北工业大学的网络攻击中使用了“魔法学校”、“小丑食物”和“诅咒之火”等 3 类针对电信运营商的攻击窃密工具。

4、隐蔽消痕类武器

TAO 依托此类武器消除其在西北工业大学网络内部的行为痕迹，隐藏、掩饰其恶意操作和窃密行为，同时为上述三类武器提供保护。现已发现 1 种此类武器：

“吐司面包”，此武器可用于查看、修改 utmp、wtmp、lastlog 等日志文件以清除操作痕迹。TAO 主要使用该武器清除、替换被控西北工业大学上网设备上的各类日志文件，隐藏其恶意行为。TAO 对西北工业大学的网络攻击中共使用了 3 款不同版本的“吐司面包”。

1.2.3 攻击溯源

(1) TAO 攻击渗透西北工业大学的流程

TAO 对他国发起的网络攻击技战术针对性强，采取半自动化攻击流程，单点突破、逐步渗透、长期窃密。

(一) 单点突破、级联渗透，控制西北工业大学网络

经过长期的精心准备，TAO 使用“酸狐狸”平台对西北工业大学内部主机和服务器实施中间人劫持攻击，部署“怒火喷射”远程控制武器，控制多台关键服务器。利用木马级联控制渗透的方式，向西北工业大学内部网络深度渗透，先后控制运维网、办公网的核心网络设备、服务器及终端，并获取了部分西北工业大学内部路由器、交换机等重要网络节点设备的控制权，窃取身份验证数据，并进一步实施渗透拓展，最终达成了对西北工业大学内部网络的隐蔽控制。

(二) 隐蔽驻留、“合法”监控，窃取核心运维数据

TAO 将作战行动掩护武器“精准外科医生”与远程控制木马 NOPEN 配合使用，实现进程、文件和操作行为的全面“隐身”，长期隐蔽控制西北工业大学的运维管理服务器，同时采取替换 3 个原系统文件和 3 类系统日志的方式，消痕隐身，规避溯源。TAO 先后从该服务器中窃取了多份网络设备配置文件。利用窃取到的配置文件，TAO 远程“合法”监控了一批网络设备和互联网用户，为后续对这些目标实施拓展渗透提供数据支持。

(三) 搜集身份验证数据、构建通道，渗透基础设施

TAO 通过窃取西北工业大学运维和技术人员远程业务管理的账号口令、操作记录以及系统日志等关键敏感数据，掌握了一批网络边界设备账号口令、业务设备访问权限、路由器等设备配置信息、FTP 服务器文档资料信息。根据 TAO 攻击链路、渗透方式、木马样本等特征，关联发现 TAO 非法攻击渗透中国境内的基础设施运营商，构建了对基础设施运营商核心数据网络远程访问的“合法”通道，实现了对中国基础设施的渗透控制。

(四) 控制重要业务系统，实施用户数据窃取

TAO 通过掌握的中国基础设施运营商的思科 PIX 防火墙、天融信防火墙等设备的账号口令，以“合法”身份进入运营商网络，随后实施内网渗透拓展，分别控制相关运营商的服务质量监控系统 and 短信网关服务器，利用“魔法学校”等专门针对运营商设备的武器工具，查询了一批中国境内敏感身份人员，并将用户信息打包加密后经多级跳板回传至美国国家安全局总部。

(2) 窃取西北工业大学和中国运营商敏感信息

(一) 窃取西北工业大学远程业务管理账号口令、操作记录等关键敏感数据

TAO 通过在西北工业大学运维管理服务器安装嗅探工具“饮茶”，长期隐蔽嗅探窃取西北工业大学运维管理人员远程维护管理信息，包含网络边界设备账号口令、

业务设备访问权限、路由器等设备配置信息等。

遭到嗅探的网络设备类型包括固定互联网的接入网设备（路由器、认证服务器等）、核心网设备（核心路由器、交换机、防火墙等），也包括通信基础设施运营企业的重要设备（数据服务平台等），内容包括账号、口令、设备配置、网络配置等信息。

1、窃取西工大核心网络设备账号口令及配置信息

北京时间 20××年 12 月 11 日 6 时 52 分，TAO 以位于日本京都大学的代理服务器（IP：130.54.××.××）为攻击跳板，非法入侵了西北工业大学运维网络的“telnet”管理服务器，上传并安装 NOPEN 木马，然后级联控制其内网监控管理服务器，上述 2 台服务器事先均已被安装“饮茶”嗅探工具。TAO 远程操控木马检索并下载被压缩加密的监听记录文件，然后清痕退出。窃取数据包括路由器、核心网设备（核心路由器、交换机、防火墙）管理账号、口令、设备配置、网络配置等信息。

2、多次窃取接入网认证设备账号口令及配置信息

（1）北京时间 20××年 5 月 30 日 0 时 28 分，TAO 以位于日本的代理服务器（IP：210.135.××.××）为攻击跳板，非法入侵了西北工业大学运维网络“telnet”管理服务器，上传并安装 NOPEN 木马，然后级联控制其内网监控管理服务器，这 2 台服务器事先均已被安装“饮茶”嗅探工具，TAO 远程操控木马检索并下载窃密记录文件后清痕退出。窃取数据包括接入网认证设备的账号、口令及配置信息。

（2）北京时间 20××年 7 月 4 日 1 时 12 分，TAO 利用位于德国莱比锡技术经济和文化学院的代理服务器（IP：141.57.××.××）作为攻击跳板，非法入侵西北工业大学运维网络“telnet”管理服务器，上传并安装 NOPEN 木马工具，级联控制其内网监控管理服务器等其他 3 台服务器，这 4 台服务器事先均已被安装“饮茶”嗅探工具，TAO 远程操控木马检索并下载窃密文件后清痕退出。

（3）北京时间 20××年 10 月 11 日 10 时 35 分，TAO 利用位于韩国首尔国立江原大学的代理服务器（IP：210.115.××.××）作为攻击跳板，非法入侵西北工业大学运维网络监控管理服务器，上传并安装 NOPEN 木马工具，然后级联控制其内网备份服务器、认证服务器等其他 4 台服务器，这 5 台服务器事先均已被安装“饮茶”嗅探工具，TAO 远程操控木马分别检索并下载窃取记录文件后清痕退出。

（4）北京时间 20××年 10 月 19 日 2 时 46 分，TAO 以位于韩国大田的高等科学技术研究学院的代理服务器（IP：143.248.××.××）为攻击跳板，非法入侵西北工业大学运维网络“telnet”管理服务器，级联控制其内网监管服务器等其他 2 台服务器，这 3 台服务器事先均已被安装“饮茶”嗅探工具，TAO 通过远程操

控木马检索并下载窃密文件，然后清痕退出。

（二）窃取西北工业大学网络设备运维配置文件和日志文件

美国国家安全局“特定入侵行动办公室”（TAO）长期攻击入侵西北工业大学网络运维管理服务器，秘密窃取网络设备运维配置文件和日志文件。

1、窃取西北工业大学网络运行日志文件

北京时间 20××年 3 月 2 日 3 时 41 分，TAO 通过位于日本的代理服务器（IP: 210.135.××.××）非法入侵控制西北工业大学 1 台网络运维管理服务器。3 时 49 分，TAO 从该运维管理服务器横向移动到另一台运维监控服务器，以特定字符串为关键词检索日志文件并进行窃取了一批系统运行日志文件和系统日常自检报告备份文件。

2、窃取西北工业大学服务器定期任务配置脚本

北京时间 20××年 10 月 11 日 10 时 41 分，TAO 通过位于韩国的代理服务器（IP: 210.115.××.××）入侵控制了西北工业大学一台内网服务器。10 时 48 分，TAO 经过两次横向移动，入侵了另一台内网服务器，访问了特定目录下的定期任务配置脚本，共检索到 14 个用于定期执行任务的配置文件。随后，一次性窃取了这 14 个文件，这些文件可用于执行定期清理、备份、检查电源等操作。

3、窃取西北工业大学公司服务器系统信息文件

北京时间 20××年 6 月 6 日 1 时 27 分，TAO 通过位于韩国的代理服务器（IP: 222.122.××.××）入侵控制了西北工业大学一台内网服务器。2 时 4 分，TAO 经过两次横向移动，入侵了另一台内网服务器，访问了目录/var/下的系统文件，窃取了 60 个常用的系统信息文件，被窃取的系统信息文件内容包含系统发行版本、用户密码哈希、用户权限、本地域名解析配置等。

（三）渗透控制中国基础设施核心设备

美国国家安全局“特定入侵行动办公室”（TAO）利用窃取到的网络设备账号口令，以“合法”身份进入中国某基础设施运营商服务网络，控制相关服务质量监控系统，窃取用户隐私数据。

1、窃取中国用户隐私数据

北京时间 20××年 3 月 7 日 22 时 53 分，美国国家安全局“特定入侵行动办公室”（TAO）通过位于墨西哥的攻击代理 148.208.××.××，攻击控制中国某基础设施运营商的业务服务器 211.136.××.××，通过两次内网横向移动（10.223.140.××、10.223.14.××）后，攻击控制了用户数据库服务器，非法查询多名身份敏感人员的用户信息。

同日 15 时 02 分，TAO 将查询到的用户数据保存在被攻击服务器/var/tmp/.2e434fd8aeae73e1/erf/out/f/目录下，被打包回传至攻击跳板，随后窃密过程中上传的渗透工具、用户数据等攻击痕迹被专用工具快速清除。

美国国家安全局“特定入侵行动办公室”（TAO）运用同样的手法，分别于北京时间 20××年 1 月 10 日 23 时 22 分、1 月 29 日 8 时 41 分、3 月 28 日 22 时 00 分、6 月 6 日 23 时 58 分，攻击控制另外 1 家中国基础设施业务服务器，非法多批次查询、导出、窃取多名身份敏感人员的用户信息。

2、渗透控制全球电信基础设施

据分析，美国国家安全局“特定入侵行动办公室”（TAO）以上述手法，利用相同的武器工具组合，“合法”控制了全球不少于 80 个国家的电信基础设施网络。与欧洲和东南亚国家的合作伙伴通力协作，成功提取并固定了上述武器工具样本，并成功完成了技术分析，拟适时对外公布，协助全球共同抵御和防范美国国家安全局 NSA 的网络渗透攻击。

（3）TAO 在攻击过程中暴露身份的相关情况

美国国家安全局“特定入侵行动办公室”（TAO）在网络攻击西北工业大学过程中，暴露出多项技术漏洞，多次出现操作失误，相关证据进一步证明对西北工业大学实施网络攻击窃密行动的幕后黑手即为美国国家安全局 NSA。兹摘要举例如下：

（一）攻击时间完全吻合美国工作作息时间表规律

美国国家安全局“特定入侵行动办公室”（TAO）在使用 tipoff 激活指令和远程控制 NOPEN 木马时，必须通过手动操作，从这两类工具的攻击时间可以分析出网络攻击者的实际工作时间。

首先，根据对相关网络攻击行为的大数据分析，对西北工业大学的网络攻击行动 98%集中在北京时间 21 时至凌晨 4 时之间，该时段对应着美国东部时间 9 时至 16 时，属于美国国内的工作时间段。其次，美国时间的全部周六、周日中，均未发生对西北工业大学的网络攻击行动。第三，分析美国特有的节假日，发现美国的“阵亡将士纪念日”放假 3 天，美国“独立日”放假 1 天，在这四天中攻击方没有实施任何攻击窃密行动。第四，长时间对攻击行为密切跟踪发现，在历年圣诞节期间，所有网络攻击活动都处于静默状态。依据上述工作时间和节假日安排进行判断，针对西北工业大学的攻击窃密者都是按照美国国内工作日的时间安排进行活动的，肆无忌惮，毫不掩饰。

（二）语言行为习惯与美国密切相关

在对网络攻击者长时间追踪和反渗透过程中（略）发现，攻击者具有以下语言特征：一是攻击者有使用美式英语的习惯；二是与攻击者相关联的上网设备均安装英文操作系统及各类英文版应用程序；三是攻击者使用美式键盘进行输入。

（三）武器操作失误暴露工作路径

20××年 5 月 16 日 5 时 36 分（北京时间），对西北工业大学实施网络攻击人员利用位于韩国的跳板机（IP:222.122.××.××），并使用 NOPEN 木马再次

攻击西北工业大学。在对西北工业大学内网实施第三级渗透后试图入侵控制一台网络设备时，在运行上传 PY 脚本工具时出现人为失误，未修改指定参数。脚本执行后返回出错信息，信息中暴露出攻击者上网终端的工作目录和相应的文件名，从中可知木马控制端的系统环境为 Linux 系统，且相应目录名“/etc/autoutils”系 TAO 网络攻击武器工具目录的专用名称（autoutils）。

出错信息如下：

```
Quantifier follows nothing in regex; marked by <-- HERE in m/* <-- HERE .log/
at ../etc/autoutils line 4569
```

（四）大量武器与遭曝光的 NSA 武器基因高度同源

此次被捕获的、对西北工业大学攻击窃密中所用的 41 款不同的网络攻击武器工具中，有 16 款工具与“影子经纪人”曝光的 TAO 武器完全一致；有 23 款工具虽然与“影子经纪人”曝光的工具不完全相同，但其基因相似度高达 97%，属于同一类武器，只是相关配置不相同；另有 2 款工具无法与“影子经纪人”曝光工具进行对应，但这 2 款工具需要与 TAO 的其它网络攻击武器工具配合使用，因此这批武器工具明显具有同源性，都归属于 TAO。

（五）部分网络攻击行为发生在“影子经纪人”曝光之前

综合分析发现，在对中国目标实施的上万次网络攻击，特别是对西北工业大学发起的上千次网络攻击中，部分攻击过程中使用的武器攻击，在“影子经纪人”曝光 NSA 武器装备前便完成了木马植入。按照 NSA 的行为习惯，上述武器工具大概率由 TAO 雇员自己使用。

（4）TAO 网络攻击西北工业大学武器平台 IP 列表

技术分析与溯源调查中，发现了一批 TAO 在网络入侵西北工业大学的行动中托管所用相关武器装备的服务器 IP 地址，举例如下：

序号	IP地址	国家	说明
1	190.242.××.××	哥伦比亚	构建酸狐狸中间人攻击平台
2	81.31.××.××	捷克	木马信息回传平台
3	80.77.××.××	埃及	木马信息回传平台
4	83.98.××.××	荷兰	木马信息回传平台
5	82.103.××.××	丹麦	木马信息回传平台

(5) TAO 网络攻击西北工业大学所用跳板 IP 列表

序号	IP地址	归属地
1	211.119.××.××	韩国
2	210.143.××.××	日本
3	211.119.××.××	韩国
4	210.143.××.××	日本
5	211.233.××.××	韩国
6	143.248.××.××	韩国大田高等科学技术研究学院
7	210.143.××.××	日本
8	211.233.××.××	韩国
9	210.135.××.××	日本
10	210.143.××.××	日本
11	210.115.××.××	韩国首尔国立江原大学
12	222.122.××.××	韩国KT电信
13	89.96.××.××	意大利伦巴第米兰
14	210.135.××.××	日本东京
15	147.32.××.××	捷克布拉格
16	132.248.××.××	墨西哥
17	195.162.××.××	瑞士
18	213.130.××.××	卡塔尔
19	210.228.××.××	日本
20	211.233.××.××	韩国
21	134.102.××.××	德国不莱梅大学
22	129.187.××.××	德国慕尼黑
23	210.143.××.××	日本
24	91.217.××.××	芬兰
25	211.233.××.××	韩国
26	84.88.××.××	西班牙巴塞罗那
27	130.54.××.××	日本京都大学
28	132.248.××.××	墨西哥
29	195.251.××.××	希腊
30	222.122.××.××	韩国
31	192.167.××.××	意大利
32	218.232.××.××	韩国首尔
33	148.208.××.××	墨西哥
34	61.115.××.××	日本
35	130.241.××.××	瑞典
36	61.1.××.××	印度
37	210.143.××.××	日本
38	202.30.××.××	韩国
39	85.13.××.××	奥地利
40	220.66.××.××	韩国
41	220.66.××.××	韩国
42	222.122.××.××	韩国
43	141.57.××.××	德国莱比锡技术经济和文化学院
44	212.109.××.××	波兰
45	210.135.××.××	日本东京
46	212.51.××.××	波兰
47	82.148.××.××	卡塔尔
48	46.29.××.××	乌克兰
49	143.248.××.××	韩国大田高等科学技术研究学院

经过持续攻坚，最终成功锁定了 TAO 对西北工业大学实施网络攻击的目标节点、多级跳板、主控平台、加密隧道、攻击武器和发起攻击的原始终端，发现了攻击实施者的身份线索，并成功查明了 13 名攻击者的真实身份。

4 结果讨论

4.1 网络安全现状

1. **整体态势良好但存在隐患：**四川省的互联网网络安全状况在 2018 年 5 月至 6 月整体评价为良，基础网络运行总体平稳，互联网骨干网各项监测指标正常，未发生较大以上网络安全事件。然而，木马或僵尸程序受控主机数量、被植入后门的网站数量、感染“飞客”蠕虫主机数量均有所增加，这些隐患不容忽视。
2. **地区分布特点明显：**通过数据分析可以发现，木马或僵尸程序控制主机主要集中在成都、绵阳、泸州、德阳、眉山等地，而被篡改的网站和被植入后门的网站也集中在这些地区。这表明，网络安全事件在地理分布上存在一定的集中性，部分地区的网络安全防护水平亟待提高。
3. **运营商影响显著：**数据表明，大部分木马或僵尸程序控制服务器和受控主机的 IP 地址都分布在四川电信网内，显示出运营商在网络安全事件中的重要角色。运营商的网络安全防护措施直接影响整体网络安全态势。

4.2 存在的问题

1. **木马或僵尸程序控制服务器和受控主机数量高：**四川省的木马或僵尸程序控制服务器和受控主机数量分别占全国总数的 3.1% 和 2.9%，尽管比例不高，但增长趋势明显，表明这一问题在省内有加剧的趋势。
2. **飞客蠕虫感染情况严重：**四川省感染飞客蠕虫的主机数量占全国总数的 4.2%，表明该类蠕虫在四川省的传播较为严重，需要特别关注和防范。
3. **网页篡改和网站后门问题突出：**被篡改的网站数量和被植入后门的网站数量在全国范围内有所减少，但四川省的情况却不容乐观，尤其是政府类网站的安全防护问题亟待解决。

4.3 改进措施

1. **加强网络安全基础设施建设：**针对木马或僵尸程序控制服务器和受控主机的增长趋势，应进一步加强网络安全基础设施建设，提升检测和防护能力，及时发现和处理异常情况。
2. **提升运营商的安全防护水平：**运营商在网络安全防护中扮演着重要角色，应加强与运营商的合作，提升其网络安全防护水平，特别是针对木马和僵尸程序的防护。
3. **加强蠕虫病毒防护：**针对飞客蠕虫的传播情况，应加强对蠕虫病毒的防护和清理，定期进行网络安全检查和病毒扫描，及时修补系统漏洞。
4. **提升政府网站安全防护能力：**政府类网站作为重要的信息发布平台，其安

全性尤为重要。应加强对政府网站的安全防护，定期进行安全审计和漏洞修补，防止网站被篡改和植入后门。

5 未来发展预测或相关建议

5.1 未来发展预测

- **网络安全威胁将持续增加：**随着信息技术的不断发展，网络攻击的手段和方式将不断升级，网络安全威胁将持续增加。未来几年，针对重要基础设施、政府机构和大企业的网络攻击将更加频繁和复杂。
- **网络攻击的隐蔽性和持久性增强：**未来的网络攻击将更加隐蔽和持久，攻击者将使用更加高级的攻击工具和技术，持续渗透和控制目标网络。这将对现有的网络安全防护手段提出更高的要求。
- **网络安全防护技术发展加速：**为了应对不断升级的网络安全威胁，网络安全防护技术将快速发展。人工智能、大数据分析等新技术将被广泛应用于网络安全防护中，提高威胁检测和响应的效率和精准度。

5.2 相关建议

- **加强网络安全人才培养：**应大力培养网络安全专业人才，提升网络安全从业人员的技术水平和实战能力，为网络安全防护提供强有力的人才支持。
- **建立完善的网络安全管理体系：**应建立和完善网络安全管理体系，明确各部门、各岗位的网络安全责任，加强网络安全管理的制度化和规范化。
- **推进网络安全技术创新：**应加大对网络安全技术的研发投入，推进网络安全技术创新，特别是针对新型网络攻击手段的防护技术，提升整体网络安全防护能力。
- **加强国际合作：**网络安全问题具有全球性，应加强国际合作，与其他国家和国际组织共同应对网络安全威胁，分享网络安全情报和防护经验，共同提升全球网络安全水平。

写作心得体会

在撰写本文的过程中，通过对大量网络安全事件数据的收集和分析，我深刻认识到了当前网络安全形势的严峻性和复杂性。网络安全不仅涉及到技术层面的问题，还涉及到管理、法律和国际合作等多个方面。在分析四川省和西北工业大学的网络安全事件时，我发现了网络攻击的多样性和复杂性，这不仅仅是技术挑战，还涉及到组织和管理的有效性。

通过此次研究，我了解到以下几点：

- 🌈 **数据的重要性和复杂性：**数据的收集和处理是整个研究的基础工作。在处理大量来自不同来源的数据时，我体会到了数据清洗和整合的复杂性。

不同来源的数据格式和内容各异，需要进行大量的预处理工作。通过 Python 编写脚本来自动化这些过程，不仅提高了效率，也确保了数据的一致性和准确性。

 **网络安全形势的严峻性：** 通过对木马僵尸程序、飞客蠕虫、网页篡改和网站后门等网络安全事件的详细分析，我认识到网络攻击手段的多样性和隐蔽性。尤其是针对重要基础设施和教育机构的攻击，显示了攻击者的专业水平和持续性。这些攻击不仅对被攻击方造成了直接的损失，也对整体网络环境的安全性提出了挑战。

 **管理和法律层面的挑战：** 网络安全不仅仅是技术问题，还涉及到管理和法律层面。如何有效地管理网络安全，制定和执行相应的安全策略，是每个组织都必须面对的问题。同时，网络安全还需要法律的保障和支持，只有在法律框架下，才能有效地追责和防范网络犯罪。

 **国际合作的必要性：** 网络安全是全球性的问题，任何单一国家或组织都无法独立应对。此次研究让我深刻认识到国际合作的重要性。只有通过国际间的信息共享和技术合作，才能更好地应对跨国界的网络攻击，提升整体的网络安全水平。

 **研究和学习的收获：** 通过这次研究，我不仅提升了自己的数据处理和分析能力，也学会了如何从多角度看待和解决网络安全问题。研究过程中遇到的各种挑战，也锻炼了我的问题解决能力和应对突发情况的能力。

总的来说，通过本文的研究，我希望能够为提升网络安全防护水平提供一些有价值的参考，也希望能引起更多人对网络安全问题的关注，共同努力应对日益复杂的网络安全挑战。网络安全是一个需要持续关注和不断改进的领域，只有通过全社会的共同努力，才能建立一个安全、可靠的网络环境。

参考文献

- [1]齐鹏云. 国防网络安全与数据治理研究 [J]. 大数据, 2024, 10 (03): 149-162.
- [2]沙默泉,高枫,涂建光,等. 数字孪生在网络安全事件管理中的应用 [J]. 网络安全技术与应用, 2024, (05): 14-17.
- [3]付东兴. 移动医疗医院信息网络安全分析及措施 [J]. 中国信息界, 2024, (02): 13-15.
- [4]汪双兔. 基于 EDR 的网络安全事件响应与处置机制研究 [J]. 通讯世界, 2024, 31 (04): 31-33.
- [5]马晓欢,李祉岐,王悦振,等. 网络攻击和网络攻击事件判定研究 [J]. 信息技术与标准化, 2024, (04): 28-34.
- [6]孙伟. 网络安全分析中的大数据技术应用 [J]. 石河子科技, 2024, (02): 17-19.

- [7]朱崑东,薛质,王洪涛,等. 证券网络安全事件应急响应评价研究 [J]. 信息安全研究, 2024, 10 (04): 368-376.
- [8]谭从龙. 基于 5G Aero MACS 网络安全分析与探讨 [J]. 网络安全和信息化, 2024, (04): 135-137.
- [9]李梦蕾. 互联网视域下移动应用数据安全问题分析 [J]. 网络安全技术与应用, 2024, (03): 62-63.
- [10]白强,胡博元,宣中忠,等. 工控网络安全风险分析与应对策略 [J]. 现代工业经济和信息化, 2024, 14 (02): 80-82. DOI:10.16525/j.cnki.14-1362/n.2024.02.023.
- [11]罗薇,汪向阳,赖栅芃. 智能网联汽车网络和数据安全分析及应对 [J]. 中国信息安全, 2024, (02): 46-48.
- [12]蒋帆. 网络安全事件响应与应急处理流程探讨 [J]. 通讯世界, 2024, 31 (01): 46-48.
- [13]傅小兵,宗春鸿,严寒冰,等. 基于 IPv6 的互联网络安全探讨 [J]. 中国新通信, 2024, 26 (02): 16-18.
- [14]徐波,王昕. 数字孪生水利工程网络安全风险分析和保障体系 [J]. 人民长江, 2023, 54 (11): 242-250. DOI:10.16232/j.cnki.1001-4179.2023.11.035.
- [15]刘谋龙. 基于大数据的网络安全分析与防范探索 [J]. 数字技术与应用, 2023, 41 (11): 228-230. DOI:10.19695/j.cnki.cn12-1369.2023.11.69.
- [16]高燕. 广电 5G 新业态下的网络安全风险分析 [J]. 广播电视网络, 2023, 30 (10): 74-76. DOI:10.16045/j.cnki.cattvtec.2023.10.003.
- [17]要丽娟,石峰. 入侵检测技术在网络安全中的应用 [J]. 电子技术, 2023, 52 (10): 346-347.
- [18]周岳亮,李宗阳,李绍铭. 基于文本的网络安全事件检测技术研究探索 [J]. 自动化与仪器仪表, 2023, (08): 79-82. DOI:10.14016/j.cnki.1001-9227.2023.08.079.
- [19]李实,李若兰,王颐硕,等. 核电行业网络安全应急演练模式研究 [J]. 网络安全与数据治理, 2023, 42 (08): 88-94. DOI:10.19358/j.issn.2097-1788.2023.08.015.
- [20]汪东皓. 甘肃省网络安全事件应急管理体系优化研究[D]. 兰州大学, 2023. DOI:10.27204/d.cnki.glzhu.2023.003893.
- [21]张宇鹏. 2022 年 5 月网络安全监测数据分析 [J]. 互联网天地, 2022, (06): 55-58.
- [22]王心怡. 近期全球网络安全形势与动向分析 [J]. 通信管理与技术, 2022, (03): 53-55.